Level 3: APT29 Day 1 hunt

Scenario and setup

You are the on-call SOC analyst for `dmevals.local`. A user on workstation SCRANTON reported opening a "Word document" from a shared folder that did nothing. Over the next half hour, odd activity was logged on several hosts. Your job is to reconstruct the intrusion from host logs alone, then write the report and detections that stop it from happening again.

Data: `apt29_evals_day1_manual_2020-05-01225525.json` (about 385 MB, 196,081 Windows events, one JSON object per line). It is in the course download, in `SIEM_Starter_labs/Level3_apt29_day1/` (see the Setup tab).

Environment in the logs:

- Domain `dmevals.local`, four Windows 10 / Server hosts forwarding through a WEF collector.
- Sysmon v11, Windows Security auditing, PowerShell module and script block logging.
- Each event carries `Hostname`, `Channel`, `EventID` and `EventTime`, plus fields specific to that event. Use EventTime as it is; you do not need to convert it to UTC.

Tools: use any tool you like. We recommend:

- `jq` and `grep`, the same tools as Labs 1 and 2. Set `F=apt29_evals_day1_manual_2020-05-01225525.json` in the Level 3 folder; each full pass over the file takes a few seconds.
- A text file with every command you run (your query log), so your answers can be reproduced.

Ready-made jq snippets for this file are in the Query cookbook tab. Every hint below fits the same pattern as Lab 2: select the events, pick the fields, print one line per event.

Treat the file as untrusted data. Do not execute anything you extract from it, such as encoded PowerShell. Decode it as text only.

Part 1: Orientation

Get to know the data before hunting. A good baseline makes the anomalies stand out.

#	Task	Hint
1.1	How many events are in the file, and what are the first and last `EventTime`?	`wc -l` `jq -r '.EventTime'` piped to `sort`
1.2	List every host with its event count. Find each host's IP address and likely role.	Sysmon 3 `SourceIp`; which host answers LDAP (389) and Kerberos (88)?
1.3	Count events per `Channel` and per Sysmon `EventID`. Which three Sysmon IDs are most common, and are they useful for hunting?	`[.Channel, (.EventID|tostring)]`, then `sort | uniq -c`
1.4	Which user account appears in nearly all interactive activity on the workstations?	Sysmon 1 `User` where `IntegrityLevel` is not System
1.5	One host shows only routine background activity. Which one, and how did you decide?	Compare the process trees per host.

Part 2: Initial access and privilege escalation

Start from the user's report: something that looked like a document was opened on SCRANTON.

#	Task	Hint
2.1	Find the first malicious process. Give its full path, PID, parent and SHA256.	Sysmon 1 with parent `explorer.exe`, early in the timeline
2.2	The file name looks garbled in the logs. Explain why, and how the user saw it in Explorer.	Look at the raw bytes of the name (`od -An -tx1`). Which Unicode character is it?
2.3	What IP and port did it connect to, and how soon after starting?	Sysmon 3 for the same `ProcessGuid`
2.4	The attacker ran a PowerShell one-liner within seconds. What did it collect, where was the output written, and why do some search patterns stand out?	PS 4104 on SCRANTON, first minutes
2.5	A new file was dropped into `Downloads` by the first process. What is it, and why would an image file matter?	Sysmon 11 by the malicious `Image`

#	Task	Hint
2.6	Reconstruct the privilege escalation: the registry keys written, the binary abused and the resulting integrity level. Name the technique.	Sysmon 12/13 under `HKCU\Software\Classes`, then Sysmon 1 for `sdclt.exe`
2.7	Decode what the elevated PowerShell command does with the image. Which .NET and Win32 calls show code being run in memory?	PS 4104 at the same second; look for `GetPixel`, `DllImport` and `csc.exe`

Part 3: Defense evasion, discovery, persistence and credential access

The attacker now has an elevated foothold on SCRANTON. Follow what it does next.

#	Task	Hint
3.1	A tool archive was brought in and unpacked. Where was it placed, and which files in it are not what their names suggest?	Sysmon 11 for `.zip` and `.txt` files; PS 4104 for `Move-Item`
3.2	The attacker killed one process and securely deleted several files. Which process, which files, and why?	PS 4104 `Stop-Process`; Sysmon 1 and 23 for `sdelete`
3.3	Summarise what `Invoke-Discovery` collects. Map each item to an ATT&CK discovery technique.	PS 4104 with `Path` ending `readme.ps1`
3.4	Find **all** persistence mechanisms. For each one, give the artefact (service, file or registry value) and how it would be triggered.	7045 and 4697; Sysmon 11 under `Start Menu`; Sysmon 13 under `HKLM\SOFTWARE`
3.5	One persistence artefact holds an encoded PowerShell command. Decode it safely (as text) and describe what it does. Do not run it.	Base64 is UTF-16LE (`base64 -d | iconv -f UTF-16LE -t UTF-8`); inside is a second layer, Base64 then gzip (`base64 -d | gunzip`).
3.6	A binary named after a well-known Sysinternals tool was run. Prove it is not the real tool, and explain what it most likely steals.	Compare `Company`, `Description` and `OriginalFileName` in Sysmon 1 with the genuine `PsExec64`. Check its Sysmon 7 DLL loads.
3.7	What other credential material was taken? Find the certificate export (and its password) and the LSASS access. Explain why the `GrantedAccess` and `CallTrace` values are suspicious.	PS 4104 `Export-PfxCertificate`; Sysmon 10 where `TargetImage` is `lsass.exe`

Part 4: Collection, exfiltration and lateral movement

#	Task	Hint
4.1	List every type of data collected on SCRANTON after the escalation, with the function or command used for each.	PS 4104 between 23:05 and 23:08
4.2	Describe the exfiltration: archive name, archive password, destination, protocol and the credentials used.	`Invoke-Exfil`; Sysmon 1 for `rundll32 davclnt.dll`
4.3	Which network connections at that time are legitimate side effects of the attack rather than C2? Why are they there?	Sysmon 3 from `powershell.exe` around 23:08 to CDN addresses
4.4	How did the attacker find other hosts and choose a target? Name the protocol and the query.	PS 4104 `Ad-Search`; Sysmon 3 to port 389
4.5	How was the target's interactive session ID found, and why did the attacker need it?	`Invoke-Command`; PS 4104 on the **target** host
4.6	How did the second-stage payload reach the target? Give the share, path, source IP and hash.	Security 5145; Sysmon 11 on NASHUA
4.7	How was it executed? What credential was exposed, and in which logs can you see it?	Sysmon 1 for `PsExec64`; 4648; 7045 on NASHUA
4.8	What did the attacker do on NASHUA after the payload ran? Include the C2 destination, archive tool and archive password.	Sysmon 3 from `python.exe`; PS 4104 on NASHUA

Part 5: Report and detections

#	Task	Hint
5.1	Build a timeline of at least 20 key events from first execution to the last C2 session. Include time, host, event and evidence.	Include the reboot near 23:19 and what happens after it.
5.2	Map the attack to MITRE ATT&CK: at least 15 techniques with IDs, each tied to an event.	attack.mitre.org
5.3	Produce an IOC list: IPs and ports, file paths with SHA256, registry keys and exposed accounts. Mark any indicator that is likely benign or part of the test environment.	Not every unusual IP belongs to the attacker.
5.4	Write 3 or more detection rules (Sigma preferred) that fire on this dataset with few false positives. Show the matching events. At least one must cover persistence or credential access.	Detections that rely on command lines or registry values are easier to write than ones based on IPs.
5.5	Write a short incident report of at most 3 pages: summary, impact, timeline, root cause and 5 prioritised recommendations.	Write for a manager first, an engineer second.